Phishing Analysebericht: Advanzia Bank

Analyst: Heinrich Habermann **Datum:** 10. März 2026 **Einstufung:** TLP:CLEAR / Credential Harvesting

1. MITRE ATT&CK Mapping

Zur systematischen Einordnung der Angreiferaktivitäten wurden folgende Taktiken und Techniken identifiziert:

- **T1566.002 (Spearphishing Link):** Einsatz eines manipulierten Verweises in einer E-Mail, um Opfer auf eine bösartige Webseite zu leiten.
- **T1583.001 (Acquire Infrastructure: Domains):** Registrierung von Domains mit Tippfehlern (Typosquatting), um legitime Dienste zu imitieren.
- **T1584 (Compromise Infrastructure):** Nutzung einer langjährig bestehenden, kompromittierten Drittanbieterdomain zur Umgehung von Reputationsfiltern.

2. Management Summary

Dieser Bericht analysiert eine zielgerichtete Phishingkampagne zum Diebstahl von Kundendaten der Advanzia Bank. Der Angriff nutzt eine Social Engineering E-Mail, die über die Infrastruktur des Marketingdienstleisters Constant Contact versendet wurde. Ziel ist eine gefälschte Loginseite auf der kompromittierten Domain `juanjosesese.com`.

3. Initialer Vektor & Social Engineering

Die Kampagne nutzt psychologische Druckmittel wie Dringlichkeit.

- **Anzeigename:** `loginADVANZIA.app` (Typosquatting durch Nutzung eines kleinen „L" statt eines „i").
- **Absenderadresse:** `advanzla-maildrop.cc@sharedl.ccsend.com`.
- **Inhalt:** Aufforderung zur Anmeldung aufgrund angeblicher Einstellungsänderungen über einen manipulierten Link.

4. Infrastruktur & Headeranalyse

Die technische Prüfung der E-Mail Header erfolgte mit **MXToolbox**.

- **Authentifizierung:** SPF, DKIM und DMARC lieferten das Ergebnis **PASS**, da die Angreifer die legitime Infrastruktur von Constant Contact missbrauchten.
- **Versandserver:** IP 208[.]75[.]122[.]14 (Waltham, USA).

5. Payload & Linkanalyse

- **Initialer Link:** `hxxps://oneway[.]am/ui/` (Server bei Hetzner Online GmbH).
- **Landingpage:** Eine optisch exakte Kopie des Advanzia Kundenportals.
- **Zieldomain:** `juanjosesese[.]com` (IP 37[.]153[.]93[.]10).

6. OSINT & Domainhistorie

Die Untersuchung mittels **RDAP** und **crt.sh** ergab:

- **Domainalter:** Registrierung am 16. April 2008 zur Umgehung von Reputationsfiltern.
- **Zertifikatslogs:** Gezielte Erstellung von Phishingsubdomains (z. B. `advanzla-caseid.juanjosesese.com`) seit Februar 2026.
- **Verschlüsselung:** Missbrauch kostenloser Let's Encrypt Zertifikate zur Täuschung der Nutzer.

7. Fazit

Die Täter agieren hochgradig professionell durch den Missbrauch vertrauenswürdiger Versanddienste und alter Domains. Herkömmliche Filter werden so effektiv unterlaufen.

8. Indicators of Compromise (IoCs)

- **E-Mail:** `advanzla-maildrop.cc@sharedl.ccsend.com`
- **URLs:** `hxxps://oneway[.]am/ui/`, `hxxps://advanzla-caseid.juanjosesese.com`
- **IP-Adressen:** 208[.]75[.]122[.]14; 128[.]140[.]36[.]14; 37[.]153[.]93[.]10

9. Lessons Learned & Empfehlungen

- **Time of Click Protection:** Untersuchung von Links zum Zeitpunkt des Aufrufs in isolierten Umgebungen.
- **Zertifikatsmonitoring:** Überwachung öffentlicher Register auf Typosquatting Domains.
- **Physische Sicherheitsschlüssel:** Zwingender Einsatz von MFA (FIDO2), da Passwörter allein keinen Schutz vor Credential Harvesting bieten.
- **Awareness:** Aufklärung über die begrenzte Aussagekraft von HTTPS Symbolen.